

Final Red Team Capstone

End-to-End Authorized Engagement: Scope -> Recon -> Exploitation -> Privilege -> Pivot -> AD -> Detection -> Reporting

Learning objectives

- Menjalankan simulated engagement end-to-end dengan scope, evidence, safety, cleanup, dan reporting yang konsisten - bukan sekadar menyelesaikan flags.
- Menggabungkan recon, network/web/API enumeration, vulnerability validation, controlled exploitation, privilege transition, pivoting, lateral movement, AD reasoning, detection-aware operations, dan professional reporting.
- Menentukan kapan harus berhenti, kapan evidence sudah cukup, kapan hypothesis harus ditolak, dan kapan sebuah action membutuhkan explicit scope change.
- Menghasilkan final deliverable yang dapat dipahami executive, engineering, security operations, dan reviewer teknis tanpa bergantung pada chat/walkthrough.

Prerequisites & recommended environment

- Module 00-25 sudah dipelajari; khususnya scope/RoE, evidence, Burp/web/API, exploitation, privesc, AD, pivoting, ATT&CK, detection, dan reporting.
- Omarchy/Arch workstation, Docker, OpenSSH client, Nmap, curl, jq, Python 3, sha256sum. Optional: isolated GOAD/MINILAB untuk enterprise extension.

omarchy pkg add docker nmap openssh curl jq python

Authorization boundary - Semua aktivitas capstone hanya untuk lab lokal yang disertakan, VM milik sendiri, GOAD/HTB/THM/PortSwigger yang explicitly authorized, atau engagement dengan izin tertulis. Discovery terhadap asset baru tidak otomatis memperluas scope.

1. Capstone Mindset: Outcome, Evidence, dan Restraint

Final capstone bukan ujian seberapa banyak tool yang bisa dijalankan. Tujuannya adalah membuktikan bahwa lo bisa mengelola ketidakpastian secara metodis: mulai dari scope, membangun hypothesis dari observations, memilih action yang proporsional, memvalidasi impact minimum yang diperlukan, menjaga evidence, lalu membersihkan perubahan dan mengkomunikasikan hasil.

Prinsip	Praktik
Hypothesis-driven	Setiap active test menjawab pertanyaan; jangan scan/fuzz tanpa tujuan.
Minimum sufficient proof	Buktikan impact dengan perubahan paling kecil; hindari destructive proof bila evidence lain cukup.
Evidence before escalation	Simpan baseline + modified result sebelum berpindah tahap.
Scope before curiosity	Asset baru = candidate; validasi authorization sebelum active testing.
Stop conditions matter	Instability, real customer data, unexpected external routing, atau scope ambiguity = stop/escalate.
Cleanup is part of success	Tunnel, account, artifact, container, listener, task, dan temp file harus diinventory lalu diverifikasi hilang.

2. Engagement Scenario

Scenario inti menggunakan micro-enterprise Docker lab yang sengaja vulnerable tetapi dibatasi ke host lokal. Lo berperan sebagai assessor eksternal dengan objective mengambil dummy file objective.txt dari internal workstation, sambil meminimalkan perubahan dan mendokumentasikan seluruh attack chain.

Omarchy Host

```

|-- capstone-attacker (DMZ only)
|
|-- edge-web :8080 [path traversal training flaw]
|
|-- jump-host :22 [dual-homed]
|
|-- internal-api :8081 [token-gated training API]
|-- internal-ssh :22 [objective host]
```

Zone / asset	Purpose	Expected access
capstone-attacker	Controlled attacker shell with nmap/curl/ssh/jq.	DMZ only; no internal NIC.
edge-web	Initial web attack surface.	Reachable from attacker.
jump-host	Pivot + constrained local privilege transition.	DMZ + internal.
internal-api	Internal-only API exposing a dummy lateral credential after token proof.	Internal network only.
internal-ssh	Final workstation containing objective.txt.	Internal network only.

Training secrets - Semua password/token/flags di package adalah dummy. Jangan pernah reuse credential tersebut di sistem nyata. Lab intentionally insecure dan harus dihancurkan setelah exercise.

3. Rules of Engagement for the Capstone

Allowed	Not allowed
Discovery/enumeration pada capstone Docker networks.	Host/LAN/public scanning di luar lab.
Web proof pada edge-web training endpoints.	DoS, high-rate fuzzing, destructive DB/file actions.
SSH menggunakan dummy credentials yang ditemukan dari lab.	Credential guessing terhadap akun lain atau target non-lab.
Privilege-boundary proof menggunakan fixed SUID helper.	General-purpose root shell, persistence, kernel exploit.
SSH local/SOCKS/ProxyJump untuk internal lab.	Expose listener ke 0.0.0.0 / LAN tanpa need.
Read dummy objective and generate evidence.	Exfiltrate real host files/secrets or mount host filesystem.

3.1 Stop conditions

- Docker lab unexpectedly binds service ke non-loopback host interface atau route mencapai jaringan lain yang tidak dimaksudkan.

- Lo menemukan data non-training / real secret / personal data; jangan lanjut inspect - stop dan pisahkan evidence.
- Container instability membuat test berpotensi merusak host resource; stop, cleanup, rebuild.
- Exercise membutuhkan action di luar scope yang tertulis; buat change request atau ubah objective, jangan improvise.

4. Engagement Lifecycle & Decision Gates

PRE-ENGAGEMENT

- > Recon
- > Enumeration
- > Vulnerability Analysis
- > Initial Access
- > Privilege Transition
- > Internal Discovery
- > Pivot / Lateral Movement
- > Objective
- > Detection Review
- > Cleanup
- > Report / Retest

Gate	Evidence minimum sebelum lanjut
Recon -> Enumeration	Scope valid + discovered asset recorded + candidate service hypothesis.
Enumeration -> Validation	Service/protocol/version or application behavior manually verified.
Validation -> Exploitation	Root cause/prerequisites plausible; proof action documented; rollback/cleanup understood.
Access -> Privilege	Current identity/context known; privilege path tied to specific misconfiguration.
Privilege -> Pivot	Dual-homing/internal route evidenced; tunnel target and listener binding planned.
Pivot -> Lateral	Authorized credential/context + destination + exact purpose documented.
Objective -> Close	Objective evidence captured; no reason for further access.
Close -> Report	Cleanup verified + evidence manifest + limitations + activity timeline complete.

5. Lab Build & Safety Architecture

Package menggunakan Docker Compose dan attacker container terpisah. Ini penting: assessment dilakukan dari namespace attacker, bukan langsung dari host, sehingga internal-only network tidak menjadi target normal dari attacker. Jump host adalah satu-satunya container dual-homed.

```
cd modules/26-final-red-team-capstone/labs
./capstone-lab.sh build
./capstone-lab.sh create
./capstone-lab.sh status
./capstone-lab.sh shell
```

Sebelum test, jalankan segmentation-check.sh dari attacker. Expected: edge/jump reachable, internal API/SSH direct tidak reachable. Jika direct access ternyata tersedia karena environment/networking berbeda, anggap segmentation assumption gagal; dokumentasikan dan jangan mengklaim pivot sebagai required control boundary.

6. Phase 0 - Pre-Engagement & Workspace

```
./workspace-init.sh capstone26
python validate-scope.py scope.json
```

Workspace memisahkan admin/scope, notes, raw evidence, normalized evidence, findings, attack path, cleanup, report, dan QA. Semua notes penting timestamp UTC. Scope validator hanya memeriksa struktur; PASS bukan pengganti legal authorization.

Artifact	Isi minimum
scope.json	Targets, networks, ports/services, window, allowed/prohibited techniques, contacts, stop conditions.
activity.jsonl	Timestamp, operator, asset, action, purpose, result, evidence path.
asset-inventory.csv	Asset, zone, source, reachability, services, scope status, notes.
hypotheses.md	Observation -> hypothesis -> test -> result -> confidence -> next action.
cleanup.md	Artifacts/tunnels/accounts/processes/files + owner + verification result.

7. Phase 1 - Recon & Enumeration

Mulai dari attacker container. Tujuan awal: petakan hanya DMZ yang diberikan scope, kemudian lakukan service verification. Gunakan Nmap output sebagai observation awal, bukan final truth.

```
nmap -sn 10.26.10.0/28
nmap -sT -sV -n -p 22,8080 10.26.10.0/28
curl -i http://10.26.10.20:8080/
```

7.1 Questions yang harus dijawab

- Host mana reachable dan dari zone mana?
- Port/service mana yang benar-benar memberi response protocol yang sesuai?
- Ada web input, download, auth, API, atau identifier yang dapat diuji secara controlled?
- Apa baseline response sebelum modified request?

8. Phase 2 - Web Validation & Initial Access

edge-web menyediakan path traversal training flaw. Jangan langsung baca file sebanyak mungkin. Tujuan proof hanya membuktikan containment failure dan mengambil satu dummy credential file yang memang ditempatkan untuk chain capstone.

```
curl -s 'http://10.26.10.20:8080/download?file=welcome.txt'
curl -s 'http://10.26.10.20:8080/download?file=../../secrets/jump-credential.txt'
```

Simpan baseline + modified response. Root cause yang harus lo tulis: user-controlled relative path digabungkan ke filesystem path tanpa canonicalization + base-directory enforcement. Impact capstone: disclosure satu dummy credential yang memungkinkan SSH ke jump host.

Minimum proof - Setelah dummy jump credential terbukti readable, berhenti melakukan arbitrary file traversal. Evidence untuk finding sudah cukup; jangan menjelajah filesystem container.

9. Phase 3 - Jump Access & Privilege Transition

```
ssh pivot@10.26.10.30
# password dari training evidence
id
ip -brief addr
ip route
find / -perm -4000 -type f 2>/dev/null
```

Jump host memiliki satu SUID helper khusus lab: /usr/local/bin/capstone-proof. Binary ini tidak memberi arbitrary command execution; ia hanya membaca root-owned /root/internal-token.txt. Tujuannya melatih enumeration -> privilege boundary proof -> evidence tanpa memberikan general root shell.

```
/usr/local/bin/capstone-proof
```

Yang harus dicatat	Kenapa
Current uid/groups	Baseline privilege context.
SUID owner/mode/hash	Bukti privileged executable dan artifact identity.
Fixed behavior	Helper hanya melakukan one-purpose privileged read.
Output token	Dummy evidence untuk internal API; treat as sensitive training credential.
Remediation	Remove unnecessary SUID; least privilege; safe privileged broker if needed.

10. Phase 4 - Internal Discovery & Pivoting

Buktikan jump host dual-homed dan attacker tidak langsung berada di internal zone. Gunakan local forward atau ProxyJump sesuai purpose. Pilih tunnel sesempit mungkin.

```
# Dari attacker container
ssh -N -L 127.0.0.1:9081:10.26.20.40:8081 pivot@10.26.10.30
```

```
# terminal lain di attacker
curl -s http://127.0.0.1:9081/health
```

Untuk enumerasi internal yang butuh beberapa destination, SOCKS dapat digunakan, tetapi jangan otomatis memakai broad dynamic tunnel jika satu local forward sudah cukup. Dokumentasikan listener bind, destination, purpose, start/stop time, dan process PID.

11. Phase 5 - Internal API & Lateral Movement

Gunakan token dari privileged proof ke internal API. API hanya mengembalikan dummy credential untuk internal-ssh bila token benar. Ini melatih chain evidence: web disclosure -> jump access -> privilege transition -> internal API auth -> lateral SSH.

```
curl -s http://127.0.0.1:9081/api/ops/credential \
-H 'X-Training-Token: <TOKEN>' | jq .
```

Setelah memperoleh dummy internal credential, gunakan jump path untuk autentikasi ke internal workstation. Prefer ProxyJump agar route jelas dan tidak perlu expose service ke host.

```
ssh -J pivot@10.26.10.30 operator@10.26.20.50
cat ~/objective.txt
```

Objective boundary - Begitu objective.txt terbaca dan di-hash/catat, objective tercapai. Jangan lanjut mencari file lain, credential lain, atau persistence. Capstone menilai restraint sama pentingnya dengan access.

12. Enterprise Extension - Active Directory Track (Optional)

Docker core capstone tidak berpura-pura menjadi Active Directory. Untuk menguji Module 18-20, gunakan GOAD/MINILAB atau platform AD resmi secara terpisah, pada isolated virtual network. Objective extension adalah menghasilkan satu attack-path hypothesis yang tervalidasi sampai batas aman, bukan mengejar Domain Admin tanpa alasan.

Step	Deliverable
DC/DNS discovery	Domain/DC inventory + SRV evidence.
Directory enumeration	Users/groups/computers/SPNs/GPO/trust snapshot.
BloodHound	Scoped collection + graph screenshot/query notes.
Attack-path analysis	Start principal -> relationship -> target privilege; prerequisites labelled.
Controlled validation	Only technique explicitly allowed by lab; minimum sufficient proof.
Detection review	Expected events/telemetry + observed outcome where available.
Cleanup	Tool artifacts/tickets/temp files removed where applicable.

GOAD isolation - GOAD is intentionally vulnerable. Never bridge/expose it to public or untrusted networks. Keep snapshots and a clean rollback point.

13. Detection-Aware Review

Setelah objective, jangan langsung tutup lab. Gunakan Module 22-24 mindset untuk merekonstruksi footprint: process, auth, network, file, application logs, tunnel state, dan event timing. Klasifikasikan defensive outcome per step: blocked, detected, logged-only, missed, atau not-testable.

Capstone step	Expected telemetry candidates
Nmap / HTTP enum	Network connection logs, web access logs, packet capture.
Path traversal	HTTP request path/query + application access/error logs.
SSH to jump	sshd auth/session logs, source/destination connection.
SUID helper	Process execution + file access where auditing exists.
Tunnel	Long-lived ssh process, local listener, internal destination connections.
Internal API	API access log + token-auth decision.
Lateral SSH	Second auth/session + process context on internal host.

Jika sensor/log tidak tersedia, status adalah not-testable - jangan menyebut “missed detection”. Bedakan telemetry presence, analytic generation, alerting, dan analyst response.

14. Evidence & Chain of Custody Lite

Capstone memakai evidence manifest, bukan formal forensic chain of custody. Setiap material claim harus punya raw artifact + path referensi. Hash evidence setelah capture, jangan setelah lo edit. Sanitized report evidence dibuat sebagai derivative, raw original tetap restricted.

```
./evidence-manifest.sh capstone26/02-evidence capstone26/08-qa/evidence-manifest.sha256
sha256sum -c capstone26/08-qa/evidence-manifest.sha256
```

Evidence class	Contoh
Recon	Nmap .nmap/.xml, host/service inventory.
Web	Baseline + traversal request/response.
Identity	SSH login context, id/groups, authorization result.
Privilege	SUID listing + fixed helper output.
Pivot	ssh command (redacted secret), listener/socket state, internal reachability proof.
Objective	objective.txt hash / minimal content proof.
Detection	log excerpts / pcap / outcome matrix.
Cleanup	Before/after process/container/listener/artifact checks.

15. Cleanup & Verification

Cleanup adalah explicit phase. Tutup tunnel, keluar dari sessions, hapus temporary local evidence yang tidak perlu dari target, lalu destroy lab. Jangan menghapus logs target hanya agar “bersih”; cleanup berarti menghapus artifacts yang lo buat, bukan menghapus audit trail.

```
pkill -f "ssh -N -L 127.0.0.1:9081" || true
./capstone-lab.sh cleanup
./cleanup-check.sh
```

15.1 Cleanup acceptance

- Tidak ada capstone containers/networks yang masih berjalan.
- Tidak ada local forwarding/SOCKS listener yang tersisa.
- Tidak ada temp credential file di attacker workspace di luar evidence store.
- Tidak ada persistence/account/service/task yang dibuat.
- Evidence/report workspace tetap ada sesuai retention plan dan permission private.

16. Professional Report Deliverable

Gunakan template Module 25. Report final capstone harus menjelaskan chain, bukan hanya daftar findings. Minimum 5 findings/observations yang tervalidasi dari local lab atau optional enterprise extension.

Section	Acceptance criteria
Executive summary	Outcome, material chain, controls, priorities, limitations <= 1 page.
Scope/RoE	Assets, networks, window, allowed/prohibited actions, stop conditions.
Methodology	Recon -> validation -> access -> privilege -> pivot -> objective -> detection -> cleanup.
Attack path	Validated transitions, gained capability, evidence refs, break points.
Detailed findings	Root cause, preconditions, evidence, reproduction, impact, remediation, retest criteria.
Detection review	Outcome status + telemetry prerequisites per material step.
Cleanup	Artifacts created, removal action, verification result.
Limitations	What was not tested and why; no implied coverage.
QA	Evidence manifest PASS + report QA + manual review.

17. Scoring Rubric

Area	Weight	Pass evidence
Scope & safety	15%	No out-of-scope action; stop conditions understood; lab isolated.
Methodology	15%	Hypotheses and decision gates visible; no tool-spam.
Technical validation	20%	Web, access, privilege, pivot/lateral chain validated with minimum proof.
Evidence quality	15%	Baseline/delta, timestamps, paths, hashes, activity timeline.
Detection awareness	10%	Expected vs observed telemetry; no unsupported detection claims.
Cleanup	10%	Listeners/artifacts/lab removed and verified.
Reporting	15%	Clear attack path, reproducible findings, actionable remediation, QA pass.

Suggested pass: >= 80% dan zero critical safety failure. Safety failure seperti scanning target non-lab, exposing vulnerable service ke LAN/public, atau retaining real secrets = automatic fail/rebuild exercise.

18. 16 Guided Labs

Lab 01 - Initialize engagement

Create workspace, read RoE, validate scope.json, record operator identity and start UTC.

Lab 02 - Build lab

Build/create Docker environment; inspect network/container topology without changing it.

Lab 03 - Segmentation baseline

Prove attacker can reach DMZ but not internal zone directly.

Lab 04 - Recon

Discover scoped hosts/services; save Nmap normal + XML evidence.

Lab 05 - Web baseline

Map edge-web endpoints and store baseline responses.

Lab 06 - Vulnerability validation

Confirm traversal with one controlled file and write a finding draft.

Lab 07 - Initial access

Use disclosed dummy credential to SSH to jump; inventory identity/network.

Lab 08 - Privilege path

Enumerate SUID; run fixed capstone-proof; capture minimal privileged evidence.

Lab 09 - Pivot design

Choose local forward vs SOCKS; document why, listener bind, destination, cleanup command.

Lab 10 - Internal API

Reach API through tunnel, authenticate with training token, record response.

Lab 11 - Lateral movement

Use obtained dummy credential via ProxyJump to internal workstation.

Lab 12 - Objective

Read/hash objective.txt; stop additional access.

Lab 13 - Detection review

Build timeline and classify each major step blocked/detected/logged-only/missed/not-testable.

Lab 14 - Cleanup

Close tunnels, sessions, destroy lab, run cleanup-check.sh.

Lab 15 - Evidence integrity

Generate/verify SHA-256 manifest and ensure report evidence references raw artifacts.

Lab 16 - Reporting

Assemble final report, attack-path card, remediation roadmap, limitations, and QA outputs.

19. Capstone Challenge - No Walkthrough Mode

Setelah guided run, rebuild lab dari clean state dan ulangi tanpa membaca source code Docker/application. Gunakan hanya scope, network ranges, target names, dan objective. Jangan memakai command history dari guided run. Tujuannya menguji apakah methodology sudah menjadi kebiasaan.

Deliverable	Minimum
Engagement plan	Scope + RoE + stop conditions + safety checks.
Asset/service inventory	Source + reachability + validation notes.
Hypothesis log	>= 6 hypotheses; includes rejected/false hypotheses.
Attack path	Initial surface -> objective; every transition backed by evidence.
Findings	>= 5 with root cause + remediation + retest criteria.
Detection matrix	Expected vs observed per major phase.
Cleanup record	Before/after verification.
Final report	Professional report + evidence manifest + QA pass.

Graduation criterion - Lo selesai master curriculum ketika lo bisa menerima authorized environment yang belum pernah dilihat, menentukan scope dan methodology sendiri, menghasilkan evidence yang defensible, mencapai objective tanpa melewati safety boundary, membersihkan artifacts, dan menyerahkan report yang dapat ditindaklanjuti.

20. Troubleshooting & Common Failure Modes

Problem	Diagnosis / response
Internal target reachable directly	Segmentation assumption invalid; inspect Docker networks/routes. Document limitation; do not fake pivot requirement.
Nmap shows filtered/closed unexpectedly	Verify container health, target IP, network attachment, and protocol manually.
SSH forward starts but curl fails	Check listener with ss -ltnp, ExitOnForwardFailure, jump reachability to internal destination.
Credential chain fails	Re-check exact evidence, whitespace/newline, user, destination; do not brute-force alternatives.
SUID helper missing	Rebuild jump image; verify mode/owner with ls -l and image build logs.
Evidence manifest fails	File changed after hashing; preserve original, regenerate manifest only with documented reason.
Report claim stronger than proof	Downgrade claim or collect scoped evidence; never inflate impact.
Detection unavailable	Mark not-testable and state missing telemetry/sensor prerequisite.

21. Final Cheat Sheet

Phase	Ask yourself
Scope	Am I authorized to touch this exact asset/action now?
Recon	What do I know, and what is still inference?
Enumeration	Did I manually verify the protocol/behavior?
Validation	What root cause/prerequisite explains this observation?
Exploit	What is the minimum proof and cleanup path?
Privilege	What boundary changes, and why?
Pivot	What is the narrowest tunnel that solves the task?
Lateral	Do I have authorized credentials and a reason to enter this host?
Objective	Is the goal met? If yes, stop expanding access.
Detection	Was telemetry present? analytic? alert? response?
Cleanup	What did I create/change, and did I verify removal?
Report	Can another person reproduce, remediate, and retest without asking me?

22. After-Action Review & Self-Assessment

Setelah guided dan no-walkthrough run, lakukan AAR sebelum melihat source code atau solution notes. Tujuannya bukan mencari pembenaran bahwa chain berhasil, tetapi mengidentifikasi reasoning gap, automation dependency, evidence gap, dan decision yang terlalu agresif/pasif.

Question	Evidence yang harus lo punya
Apa hypothesis yang salah?	Rejected hypotheses + observation yang membantahnya.
Di mana waktu paling banyak habis?	Activity timeline + notes; pisahkan knowledge gap dari tooling issue.
Tool mana yang dipakai tanpa memahami output?	Satu contoh output yang lo validasi manual setelahnya.
Di mana scope/safety hampir terlewat?	Decision gate / stop-condition note + corrective action.
Evidence apa yang terlambat dikumpulkan?	Finding yang sulit direproduce atau timeline yang punya gap.
Apa control yang paling efektif?	Attack-path break point atau detection outcome yang menurunkan impact.

Apa yang akan diubah di run berikutnya?	Tiga process improvements yang measurable.
---	--

22.1 Skill confidence matrix

Domain	0-1	2-3	4-5
Linux / Windows fundamentals	Masih cari command dasar	Bisa enumerate dengan notes	Bisa explain why + automate safely
Networking / HTTP	Hafal syntax	Bisa trace request/route	Bisa reason dari packet/protocol behavior
Web / API	Cari payload	Bisa baseline/delta/root cause	Bisa design validation + remediation
Exploitation / privesc	Tool-dependent	Bisa audit prerequisites	Bisa minimum-proof + cleanup + evidence
AD / pivoting	Graph/tool-driven	Bisa explain relationships	Bisa reason attack path + break points
Detection / OPSEC	Fokus bypass	Bisa predict telemetry	Bisa validate controls dan classify result
Reporting	Command dump	Reproducible findings	Executive + technical + retest-ready deliverable

Score 0-5 untuk setiap domain dan tulis satu evidence konkret. Jangan memberi skor dari rasa percaya diri; gunakan artifact dari capstone sebagai proof.

23. Graduation Checklist & Next Specialization

Checkpoint	Done when
Unknown environment	Lo bisa mulai dari scope dan inventory tanpa walkthrough.
Reasoning	Setiap active action punya hypothesis/purpose yang tertulis.
Safety	Lo berhenti saat objective tercapai atau boundary menjadi ambigu.
Evidence	Finding material punya baseline/delta/raw evidence/hash.
Enterprise	Lo memahami identity, AD relationships, network segmentation, dan attack paths.
Defense-aware	Lo bisa menjelaskan expected telemetry dan detection outcome.
Cleanup	Lo dapat membuktikan artifacts/tunnels/lab state sudah dibersihkan.
Communication	Report bisa dipakai untuk remediation dan retest tanpa walkthrough tambahan.

23.1 Pilihan specialization setelah master curriculum

Track	Fondasi berikutnya
Advanced Active Directory	AD CS, delegation, trusts, hybrid identity, BloodHound path analysis yang lebih dalam.
Web / API specialist	Advanced request smuggling, browser security, OAuth/OIDC, GraphQL, race/logic, source review.
Exploit development	C/C++, assembly, debuggers, mitigations, memory corruption, reverse engineering.
Red Team operator	Enterprise C2 in authorized range, infrastructure, campaign planning, collaborative operations, detection validation.
Cloud / identity	AWS/Azure/Entra/IAM, cloud logging, container/Kubernetes security.
Detection engineering / purple team	Sigma, SIEM, EDR telemetry, ATT&CK analytics, adversary emulation, regression tests.

Sertifikasi dapat dipakai sebagai benchmark - misalnya CPTS/PNPT/OSCP untuk pentest methodology dan hands-on, lalu track AD/red-team/cloud sesuai tujuan. Skill tetap dibuktikan lewat repeatable lab work, notes, evidence, dan report quality - bukan badge saja.

24. References

- NIST SP 800-115 - Technical Guide to Information Security Testing and Assessment - <https://csrc.nist.gov/pubs/sp/800/115/final>
- MITRE ATT&CK Enterprise - <https://attack.mitre.org/>
- OWASP Web Security Testing Guide - <https://wstg.owasp.org/>
- OWASP API Security Top 10 - <https://owasp.org/API-Security/>
- FIRST CVSS v4.0 - <https://www.first.org/cvss/v4.0/>
- PortSwigger Web Security Academy - <https://portswigger.net/web-security>
- Docker Networking - <https://docs.docker.com/engine/network/>
- OpenSSH manual - <https://man.openbsd.org/ssh>
- GOAD - Game of Active Directory - <https://github.com/Orange-Cyberdefense/GOAD>
- OffSec PEN-200 / OSCP - <https://www.offsec.com/courses/pen-200/>
- Hack The Box Academy Penetration Tester path - <https://academy.hackthebox.com/path/preview/penetration-tester>

The core capstone is intentionally local and disposable. Enterprise AD extension requires a separately isolated, explicitly authorized training environment.